

The Forcing Function

3HUE's best customer is a company that has just been told to prove it by someone with leverage — and has nobody inside to do it.

WHAT THIS IS

A qualification instrument, not a persona poster. Score a prospect against the model below, get a tier and a play. Built for sales calls, campaign targeting, and deciding what to walk away from.

WHERE IT COMES FROM

Derived from *The Maturity Gap* research: 25+ industry reports from 2024–2026 plus logged-in social listening across LinkedIn, X, Reddit, YouTube and TikTok.

CONFIDENCE

The segments and triggers are evidence-backed. The revenue bands and the 60/25/15 focus split are judgment calls to be corrected against 3HUE's own won-lost data once it is available.

HUE 01 · PRIMARY

The Provable Vendor

Software and tech-enabled services companies whose next contract depends on evidence they cannot currently produce.

≈60% of go-to-market effort

HUE 02 · LEVERAGE

The Portfolio

Sub-\$25B private equity sponsors and family offices carrying cyber risk across operating companies with no standard.

≈25% — one relationship, many logos

HUE 03 · CREDIBILITY

The Regulated Operator

Banks, credit unions, lenders and OT-heavy operators with governance on paper and an examiner in the building.

01 The fit model

Eight criteria, 100 points. The first one is worth a quarter of the score on its own, because the research is unambiguous: organizations do not buy maturity on principle. They buy it when a customer, an insurer, an investor or a regulator makes them. Score honestly — the model earns its keep by disqualifying, not by flattering the pipeline.

1. Is there a live forcing function?

25 pts

A named deal, renewal, exam, diligence process or insurance date — not a general intention to improve. 61% of organizations were required to hold a certification to win or renew a contract; 38% had already lost revenue over it.

Named and dated 25

2. Who owns security today?

15 pts

The capacity gap is the product. 68% of organizations have one or fewer full-time security staff while 93% call security a top priority. A prospect with a CISO and a team does not need 3HUE to run the program.

IT or the CTO wears the hat 10

3. Can we reach the person who signs?

12 pts

In this segment the economic buyer is usually the CEO, COO or operating partner — the person whose deal, exit or exam is at risk. A champion with no line to that person stalls at proposal.

Champion only, warm path up 6

4. Size and shape

12 pts

Below roughly 20 people the budget is bound to the tool tier; above a few thousand there is an internal team and a procurement process 3HUE does not win on price. Regulated operators sit higher because the program is bigger.

50–500 staff, or 200–2,000 regulated 12

5. Is someone demanding proof?

10 pts

Distinct from the trigger: this is the standing pressure. 65% of organizations say customers, investors and suppliers now demand more evidence of compliance than before, and 80% of companies using AI are already fielding customer questions about AI risk.

6. Environment complexity

8 pts

Multi-cloud, OT, multi-entity or AI in production is where 3HUE's architecture depth and AiVRIC's telemetry are worth paying for. A single-SaaS shop can be served by a platform alone.

Multi-cloud, OT, multi-entity or production AI 8

7. Tools bought, nobody operating them

8 pts

The sharpest wedge in the market. 86.8% of small businesses have deployed MFA but only 51.1% require it everywhere; 88.4% hold backups and 61.4% have tested them. A prospect already paying for Vanta, Drata or a CSPM and getting no program out of it is pre-qualified.

Tools bought piecemeal, no owner 4

8. Does the work recur?

10 pts

Readiness projects end; operated programs do not. Multi-entity structures, annual audit cadences and continuous monitoring obligations are what turn a first engagement into an annuity. 97% of organizations now run two or more audits a year.

Annual audit cycle ahead 5

FIT SCORE

80 / 100

• TIER A • PURSUE NOW

Lead with the Snapshot. Scope it to the specific obligation, put a date on the readiness letter, and price against the deal at risk rather than against a tool.

Tier A • Pursue now	70-100
Tier B • Nurture to a trigger	45-69
Tier C • Decline or refer	0-44

Clear and score a new prospect

Pre-filled with an illustrative prospect: a 180-person freight-software company that lost a renewal over a SOC 2 request, has an IT director wearing the security hat, and pays for a GRC tool nobody operates.

02 The three segments

Ranked by where the effort should go, not by deal size. Each one is a different trigger, a different buyer and a different first sentence — but the same underlying product: a governed program someone else operates and can prove.

HUE 01 PRIMARY • ≈60% OF EFFORT

The Provable Vendor

A US B2B software or tech-enabled services company, 50–500 employees and roughly \$10M–\$150M revenue, selling into enterprise, healthcare, financial services or public-sector buyers. Multi-cloud or SaaS-heavy. Zero or one security FTE. Frequently VC- or PE-backed. Their product is fine; their evidence is not.

WHAT SETS THEM OFF

- A deal or renewal frozen pending SOC 2 Type II or ISO 27001
- A 200-question security questionnaire with a due date
- A customer asking how they govern AI in the product
- An insurance renewal with new control conditions
- Diligence ahead of a raise or an acquisition

HOW THEY DESCRIBE IT

"Call us back when you have a SOC 2 in hand to provide."

Reported by a sales leader on LinkedIn, May 2026

Their own version: *"I'm a founder, not a compliance expert."* They are not shopping for governance. They are trying to unfreeze revenue.

WHO IS IN THE ROOM

Signs: CEO or COO. **Champions:** CTO or VP Engineering, and increasingly the Head of Sales whose deal is blocked. **Influences:** the lead investor, outside counsel, the insurance broker. There is usually no CISO to sell to — which is the point.

WHAT 3HUE SELLS THEM

Snapshot scoped to the actual obligation → readiness program with continuous evidence on AiVRIC → managed program with questionnaire ownership and auditor management. The differentiator is scope negotiation: telling them what they *don't* have to do.

PROOF 3HUE ALREADY OWNS

Transit Technologies is this exact story: no formal security program, then SOC 2 Type I with zero findings and multi-entity Type II across a software portfolio. That case study should be the segment's landing page.

WHY THEY CHOOSE 3HUE OVER THE ALTERNATIVES

Against Vanta or Drata: a platform hands you a longer to-do list; 3HUE runs the list. Against an MSP's vCISO add-on: 67% of MSPs now offer one, and it is advisory bolted to a help desk. Against a solo consultant: continuity, evidence automation, and someone to answer the questionnaire at 9pm.

HUE 02 LEVERAGE • ≈25% OF EFFORT

The Portfolio

Private equity sponsors and family offices below \$25B AUM, holding five to thirty lower-middle-market operating companies. Kroll's 2026 survey found firms above \$25B include cybersecurity in transaction diligence 81% of the time — and firms below \$25B only 29%. That 52-point gap is the entire opportunity, and those portfolios are full of Hue 01 companies.

WHAT SETS THEM OFF

- A new platform acquisition entering diligence
- Exit preparation, where a cyber finding becomes a valuation haircut
- An incident at one portfolio company
- A lender or insurer imposing conditions across the fund
- An LP asking what the fund's cyber posture actually is

THE NUMBER THAT MOVES THEM

\$2.1M average financial impact per cyber incident on a deal; 26% of firms have seen a reduced valuation or exit price.

Kroll, Private Equity Cybersecurity, Feb 2026, n=325

WHO IS IN THE ROOM

Signs: operating partner or fund CFO. **Champions:** portfolio-company CTOs, the value-creation team. **Influences:** the deal team, the insurance broker, the lender. They think in portfolios and exits, not in controls.

WHAT 3HUE SELLS THEM

Diligence-grade assessment per acquisition, one control set applied across every entity, quarterly board- and IC-ready reporting, and AiVRIC multi-tenant underneath so each company is isolated but the fund sees one view. Priced per entity with a fund-level retainer.

PROOF 3HUE ALREADY OWNS

A large North American bank: 1,000+ systems certified under a scalable GRC assessment framework. The story to tell is repeatability at scale — the same reason a sponsor should not hire a different consultant per portco.

WHY THIS SEGMENT IS WORTH 25%

One sponsor relationship converts into many logos and a standing engagement, and it puts 3HUE upstream of the Hue 01 companies rather than competing for them one at a time. It is also the segment where "will the policy actually pay?" lands hardest.

HUE 03 CREDIBILITY · ≈15% OF EFFORT

The Regulated Operator

Community and regional banks, credit unions, lenders and fintechs under BSA, GLBA, FFIEC or NYDFS; plus OT-heavy transport, energy and utility operators. Typically 200–2,000 employees. They already have frameworks, policies and a risk register. What they have is findings, an examiner and a date.

WHAT SETS THEM OFF

- Exam findings or a Matter Requiring Attention
- A third-party audit finding with a remediation clock
- A board mandate after a peer's incident
- Model-risk or AI governance obligations (SR 11-7, ISO 42001)
- Grid, safety or OT resilience requirements

THEIR PRIVATE DIAGNOSIS

"Governance existed on paper, not in operation."

Andrew Ramirez, Founder Thesis, Feb 2026

Confirmed externally: 72% of organizations still rely on periodic assessments, and 78% of those who failed a recent audit had a prior breach history.

WHO IS IN THE ROOM

Signs: CIO, CISO or Chief Risk Officer, with the audit committee behind them. **Influences:** internal audit, the examiner's letter, the board. This is the one segment where the buyer is a peer, not a novice.

WHAT 3HUE SELLS THEM

Named framework crosswalks (NIST CSF and 800-53/171 as the spine, mapped to ISO 27001, COBIT, FFIEC, SOC 2), continuous controls monitoring to replace point-in-time testing, remediation orchestration that actually closes findings, and board-ready risk translation.

PROOF 3HUE ALREADY OWNS

Andrew's own record is the pitch: FDA 483 observations closed, bank MRAs remediated, sustained audit scrutiny with zero margin for error. This is the only segment where the founder's résumé outranks any case study.

THE FRAMEWORK EXCEPTION

Everywhere else, leading with NIST, ISO, COBIT or ITIL loses the room. Here it is the examiner's vocabulary and belongs in the first sentence, the proposal and the RFP response.

03 The buying committee

Four roles decide these deals. Each hears a different sentence. The most common failure is pitching the champion's language to the person who signs.

ECONOMIC BUYER

The CEO or COO

50–500 person B2B company · signs the contract

HEARS ABOUT SECURITY WHEN

A deal, a renewal or a policy is at risk. Never before.

SAYS

“What does it cost, how long, and does it close the deal?”

FEARS

Paying \$80K for paper. Being the founder who did not take it seriously.

CONVERTS ON

Revenue framing, a fixed-scope start with a date, and the founder on the call rather than a junior team.

CHAMPION

The CTO or IT Director

Wearing the security hat alongside 20 other jobs

REALITY

Compliance drives their stack more than risk does, because budget only appears at a deadline.

SAYS

“Tell me what we don't have to do.” And: “Who is actually going to run this?”

FEARS

Engineering time burned on audit theater. Being blamed after an incident they flagged.

CONVERTS ON

Scope reduction, execution rather than advice, and evidence automation that ends the screenshot ritual.

TRIGGER OWNER

PORTFOLIO & REGULATED BUYER

The Head of Sales or RevOps

Holding the procurement email that killed the deal

KNOWS

Nothing about controls. Has never heard the phrase "System and Organization Controls."

SAYS

"We're losing to a worse product because they seemed more legit."

FEARS

The quarter.

CONVERTS ON

A trust page, a managed questionnaire response, and a readiness letter with a date they can send to procurement.

The Operating Partner or CRO

Answers to an investment committee, a board or an examiner

WANTS

Oversight across entities without hiring a CISO for each one.

SAYS

"What is our exposure across the portfolio?"
And: *"Will the policy pay out?"*

FEARS

A valuation haircut at exit. A finding that will not close. A voided claim after an incident.

CONVERTS ON

One control set across every company, diligence-grade evidence, and reporting a board can read without a translator.

04 Trigger events and how to spot them

The ICP is a description; the trigger is the timing. These are the six events worth building campaigns and alerts around, with the observable signal that betrays each one before the prospect ever raises a hand.

TRIGGER	SEGMENT	OBSERVABLE SIGNAL	OPENING MOVE
Deal blocked on SOC 2 or ISO 27001	Hue 01	Selling to enterprise with no trust page or security page on the site; a first compliance hire posted; founders posting about questionnaires. Search: <code>site:linkedin.com/posts "SOC 2" "lost a deal"</code>	Readiness letter with a date, plus scope negotiation. Price against the deal at risk.
Cyber insurance renewal or claim	All three	Renewal months are knowable through brokers. Public signals: MFA and EDR job requirements appearing suddenly; an incident at a named peer.	Attestation audit: compare what the application says to what can actually be demonstrated, before renewal.

TRIGGER	SEGMENT	OBSERVABLE SIGNAL	OPENING MOVE
Diligence or exit preparation	Hue 02	Platform acquisition and add-on announcements from sub-\$25B sponsors; a fund hiring its first value-creation or IT operating partner.	Diligence-grade assessment for the acquisition, then a fund-level standard across the portfolio.
Exam finding or MRA	Hue 03	Regulator actions and consent orders are public. Board and audit-committee changes at community FIs. Sudden GRC or internal-audit hiring.	Remediation program with continuous controls monitoring and evidence that will survive the next exam.
AI reaching production, or a customer asking about it	Hue 01 and 03	AI features shipped in the last two quarters; AI engineers hired; an AI policy page published with no controls behind it. 80% of companies using AI already field customer questions about AI risk management.	The 10-day AI Risk & Readiness Snapshot, framed as the four questions: what can it access, what can it change, who approved it, what proves it stayed inside.
Contract or regulatory deadline	Hue 01 and 03	Defense and aerospace suppliers with NIST 800-171 obligations; firms newly in scope for state privacy laws or DORA. Note CMMC Phase II was suspended July 13, 2026 — 800-171 and DFARS 7012 still apply.	"The certification paused; the controls didn't." Practical alternative to both panic and abandonment.

Building the target list. In Sales Navigator: headcount 50–500, US, industries software / IT services / financial services / transportation, then filter for companies with no security title in the org and at least one enterprise logo in their customer list. Two high-signal filters that cost nothing: a company selling to enterprise with no public trust page, and a job posting for a *first* compliance, GRC or security hire — that posting means the trigger has already fired and no program exists yet. For Hue 02, the list is sponsors, not companies: build it from fund size and recent platform announcements.

05 Who to decline

The fastest way to raise close rates is to stop working the deals that were never going to close. Each of these should be a hard stop in the first call, not a discovery to make in month two.

No external forcing function

A company that wants to "be more mature" with no customer, insurer, investor or regulator pushing will not fund it. Educate them cheaply with content and revisit when something fires.

Under ~20 people, or pre-revenue

The budget is structurally bound to the tool tier. Refer them to a compliance platform and stay useful; they become an ICP company at Series A with an enterprise pipeline.

Shopping for the fastest, cheapest certificate

This is the Delve customer. They want a document, not a program, and they will churn to whoever is faster next year. Losing them is a feature; the market watched 493 near-identical audit reports surface in March 2026.

Wants advisory only, no execution

Retainers for advice alone do not survive contact with an SMB budget — "it's execution that produces value for them." If they will not buy delivery, they are buying a coffee chat.

Has a CISO and a functioning team

Then 3HUE is competing as staff augmentation at commodity rates against firms built for it. The exception is a discrete program they cannot staff — an AI governance build, a portfolio rollout, a specific remediation.

Will not let anyone talk to the person who signs

Without the economic buyer, scope negotiation is impossible and the proposal becomes a price comparison. Ask for that access as the condition of proceeding.

Wants the certificate decoupled from the controls

Anyone asking 3HUE to make the evidence say something the environment does not support is a liability, not a client. Post-SolarWinds, the personal exposure runs both ways.

06 What to say to each

The market has already agreed that a certificate is not security — saying so is no longer differentiating. The differentiated sentence is the one that comes next: what 3HUE operates, and how the client proves it. Each block below is an opening line, the argument under it, and the proof to reach for.

"Your buyer isn't asking whether you're secure. They're asking whether you can prove it by Friday."

Then the capacity turn: you already know what to do, you just don't have anyone to do it. 68% of companies have one or fewer full-time security people while 93% call security a top priority. 3HUE scopes the obligation down to what the contract actually requires, runs it, and hands over evidence that keeps producing itself after the audit. The engineering team goes back to shipping.

Proof: Transit Technologies · SOC 2 Type I, zero findings, multi-entity Type II · founder-delivered

"Your bigger competitors run cyber diligence on 81% of deals. You run it on 29%."

The gap is not a philosophy difference, it is a staffing one — and it costs \$2.1M per incident on average, with a quarter of firms taking a valuation hit. One control set across every operating company, evidence that survives a buyer's diligence, and reporting the investment committee can read. Isolated per entity, visible at the fund level.

Proof: 1,000+ systems certified under one scalable assessment framework · AiVRIC multi-tenant

"Your controls passed in December. The question is what they were doing in March."

Named frameworks, in the examiner's language, with the operating layer underneath: 72% of organizations still run periodic assessments while 94% of CISOs say continuous monitoring works better. 3HUE closes findings and keeps them closed, because governance without operational authority is theater — and the founder has spent a career closing 483s and MRAs where the margin for error was zero.

Proof: FDA 483s closed · bank MRAs remediated · NIST, ISO, COBIT, FFIEC crosswalked to one control set

Three things never to lead with. ITIL, COBIT and TOGAF outside Hue 03 — there is no live conversation about them on any platform, and the association is "four years of talk." The phrase "compliance ≠ security" as a headline — it is now consensus, so it signals nothing; use it only as the setup for what operating the program looks like. And maturity scores as the pitch: nobody outside security knows what Level 3 means. Lead with the money, the date and the name of who is accountable.

07 Evidence base and what would sharpen this

Every figure in this profile is drawn from a named 2024–2026 source that was checked on its own page. The full research, including the social-listening exhibits with working links, is in *The Maturity Gap*.

Load-bearing sources

1. Secureframe, 2026 Cybersecurity & Compliance Benchmark — capacity gap and contract triggers

2. Kroll, Private Equity Cybersecurity, Feb 2026 — the 81% vs 29% diligence gap
3. Cybersecurity Ventures with Sophos, 2026 CISO Report — 10,000:1 business-to-CISO ratio
4. WEF Global Cybersecurity Outlook 2025 — small-organization resilience gap
5. National Cybersecurity Alliance with CISA, 2026 — deployed vs operating
6. RegScale, 2026 State of Continuous Controls Monitoring — 72% periodic vs 28% continuous
7. A-LIGN, 2026 Compliance Benchmark — audit cadence and AI questions from customers
8. Thales, 2025 Data Threat Report — audit failure and prior breaches
9. Cynomi, 2025 State of the vCISO — MSP vCISO adoption 21% → 67%
10. Chubb claim severity via Insurance Journal, May 2026 — SME vs mid-market claims
11. Andrew Ramirez, Founder Thesis and Lessons Learned in 2025
12. Social listening: LinkedIn, X, Reddit (r/msp, r/ITManagers, r/Compliance, r/smallbusiness, r/sysadmin, r/cybersecurity), YouTube and TikTok, September 2026

What would make this profile provable rather than well-reasoned

Four inputs, all internal to 3HUE, would convert judgment into fact and let the fit model be re-weighted against reality:

- **Won-lost history.** Every deal in the last 24 months tagged by segment, trigger, size and outcome. This is the single highest-value input; it would confirm or overturn the 60/25/15 split.
- **Search Console and Analytics for 3hue.net.** What people actually search to arrive, and which pages hold them. Today the site does not name NIST, ISO, CIS or COBIT anywhere public, so a whole category of intent traffic cannot find it.
- **LinkedIn page analytics for 3HUE and AiVRIC.** Who follows and visits, by title and company size, against the segments above.
- **Sales Navigator.** To size each segment in the actual territory and pull the real title distribution rather than the inferred one.

Until then, treat the segments and triggers as evidence-backed and the weightings as a starting hypothesis. Re-score twenty closed deals against the model; if the tiers do not separate wins from losses, move the weights, not the definition.

3HUE Ideal Customer Profile · version 1 · September 2, 2026 · companion to *The Maturity Gap* research dossier. Figures verified against their sources on publication date; re-check regulatory items, particularly CMMC, before any campaign.